The Aggregate Gap[1]

Supervising a swarm that spends money, measured in cents

Muhammad Hassaan Shaukat · Independent Researcher
Rızgar Ozan · Independent Researcher
With Apart Research · Swarm Alignment Hackathon 2026, Track 4

Abstract

Agent payment protocols cap each mandate, not the principal: several agents that each stay inside their own cap can together move more of one principal's money than any was allowed. We measure this aggregate gap in cents settled, not flags raised, on a seeded reproducible harness with a swarm monitor inline at a payment gateway. The monitor holds a per-payee, per-window bound against every attack tuned to it, cutting settled attack money from 1.00 to 0.43–0.67, while three held-out attacks that never cross a bound settle in full. A model supervisor appears to help, but a paired seed-by-seed ablation shows its whole measurable edge is a defect in our own payee-identity rule plus a hold-versus-freeze reaction difference, reproducible for free with two string comparisons. Live Gemini runs confirm the identity judgement a model adds is real: it merges renames and misspellings the rules miss without false-merging identifier namespaces, and an adversarial draft moved a real reviewer on zero of six unambiguous breaches. A gateway ledger built from settled instructions rather than agent reports is unchanged when agents tamper with their published logs. The durable defence is a rate bound an attacker cannot argue with; identity and time are the levers it leaves open.

1. Introduction

Payment protocols for agent swarms enforce a budget **per mandate**. Nothing enforces one **across** the mandates a single principal issues, so several agents that are each inside their own cap can move more of that principal's money than any of them was allowed to. We call this the *aggregate gap*. The human version is structuring, and banks have had rules for it for decades; the agent version is cheaper to carry out because agents can be copied, renamed and run at machine speed.

A 2026 security analysis of Google's Agent Payments Protocol (AP2) formalises constraint enforcement *within* a mandate chain: a closed mandate must stay inside its open mandate's user-approved limits, and cumulative limits must remain satisfied across reuse (Aviv et al., SR5/SR7). It also finds that attacks which steer the agent *before* it signs escape mandate-chain verification entirely. Neither line of defence binds the principal across separately issued mandates to different agents, which is the seam we study.

Our main contributions are:

- A seeded, stdlib-only harness and a gateway that scores every defence in cents settled and legitimate cents stopped, with five tuned and five held-out attacks and a named, individually removable check for each rule.
- A paired negative result: a model supervisor's entire measurable edge over the rules is a defect in our own payee-identity rule plus a hold-versus-freeze reaction difference, reproducible for free; and a one-way authority seam whose safety is a design property, not a judgement.
- Live-model evidence (Gemini): payee identity and draft persuasion, an unprompted structuring task where removing an approval threshold makes agents split payments on their own, a log-tampering demonstration, and a best-response curve with a formal leakage bound showing the defence is a rate limit, not a total.

2. Related Work

Structuring and velocity limits. Splitting a transaction to stay under a reporting threshold is the predicate of anti-money-laundering law (31 U.S.C. §5324; FATF Recommendations). Our per-payee, per-window bound is a velocity limit in the payment-processing sense; the gap we measure is that such limits bind one identity, and identities are what an attacker controls. **Sybil resistance.** Douceur (2002) shows cheap identities break any rule that counts per identity without a trusted authority; our split_distinct attack and the 28,086-destination real pool are the same lever. **Split-up attacks on agents.** Jones et al. (2025) show safe models misused in combination by decomposing a task; Makins et al. (2026) show per-instance monitors fail on distributed attacks in code. We measure the money version and price the supervision. **Collusion and control.** Motwani et al. (2024) measure secret collusion between models that share an encoding; Rose et al. (2026) detect collusion with multi-agent interpretability; Greenblatt et al. (2024) give the AI Control protocols we wire to the payment seam. **Incident.** METR (2026) and Swarm Traces (2026) document the Hugging Face swarm, including ~7% transcript spoofing and 7,905 names for ~1,200 agents, which motivate the tampering and identity experiments.

3. Methods

- **Money, not flags.** Each arm is the share of attack money that settles and the share of legitimate money stopped, in cents, per seeded log. A defence that detects late still lets the money out. 200 seeds per rule cell, 50 per model cell; Wilson 95% intervals on rates, and a paired seed-by-seed difference for the headline model-vs-rule comparison.
- **Gateway policies.** per_mandate (each agent's cap), ledger (one cap on the principal over a rolling window, calibrated from benign logs only), monitor (the swarm monitor inline), and ledger+monitor. The monitor's six checks are named and each is removable on its own.
- **Two attack sets.** Five scenarios tuned on the limits; five held out, written afterwards, whose attackers check their own budgets first (distinct payees, a rename past the cutoff, a drip slower than the window).
- **Model arms.** AI Control protocols at the seam where a payment is about to settle, with each seat's competence and honesty as free parameters offline, and live Gemini (gemini-3.5-flash-lite) for payee-identity judgement, a paired blind/draft persuasion test,

and an unprompted structuring task. The gateway consults a model only on payments the rules already let through: a model can decline to hold, never release.

- **Negative controls.** Each guard ships with a test that removes it and requires the failure to return; the tampering and identity metrics are constructed so an inert edit or a merge-everything judge is caught.

4. Results

4.1 What the rules are worth at a gateway

scenario	per_mandate	ledger	monitor	ledger+monitor
split_payment	1.00 [1.00, 1.00]	0.71 [0.70, 0.73]	0.67 [0.67, 0.67]	0.67 [0.67, 0.67]
relay	0.55 [0.50, 0.60]	0.55 [0.50, 0.60]	0.44 [0.42, 0.47]	0.44 [0.42, 0.47]
split_wide	1.00 [0.99, 1.00]	0.80 [0.78, 0.83]	0.67 [0.66, 0.67]	0.67 [0.66, 0.67]
relay_two_hop	0.55 [0.50, 0.59]	0.55 [0.50, 0.59]	0.43 [0.41, 0.46]	0.43 [0.41, 0.46]
split_alias	1.00 [0.99, 1.00]	0.71 [0.69, 0.73]	0.67 [0.66, 0.67]	0.66 [0.66, 0.67]
split_distinct	1.00 [1.00, 1.00]	0.79 [0.77, 0.82]	1.00 [1.00, 1.00]	0.79 [0.77, 0.82]
split_slow	1.00 [1.00, 1.00]	0.92 [0.90, 0.94]	1.00 [1.00, 1.00]	0.92 [0.90, 0.94]
alias_far	1.00 [1.00, 1.00]	0.80 [0.77, 0.82]	1.00 [1.00, 1.00]	0.80 [0.77, 0.82]
relay_fanout	1.00 [1.00, 1.00]	1.00 [1.00, 1.00]	0.69 [0.69, 0.69]	0.69 [0.69, 0.69]
relay_reversed	1.00 [1.00, 1.00]	1.00 [0.99, 1.00]	0.98 [0.96, 1.00]	0.98 [0.96, 0.99]

Table 1. Share of attack money that settles (lower is better), 200 seeds, Wilson 95% intervals. per_mandate is what a payment protocol enforces today.

The per-agent cap alone lets 1.00 of a tuned split leave; inline monitoring cuts that to 0.67, but the money ahead of the flag is already gone. The three held-out attacks that never cross a bound (split_distinct, split_slow, alias_far) each have recall 0.00 and settle 1.00 under both. A principal-wide ledger trades one currency for the other (Table 2): the tight setting cuts attack money to 0.10 but blocks 0.608 of a legitimate busy week; the 99th-percentile setting blocks 0.174.

arm	cap	window	attack money settled	busy-week money stopped
per_mandate	-	-	0.91	0.000
monitor	-	-	0.75	0.000
ledger_w20_q0.5	37937	20	0.10	0.608
ledger_w20_q0.9	43747	20	0.16	0.595
ledger_w20_q0.99	49060	20	0.23	0.561
ledger_w20_q1.0	50877	20	0.27	0.542
ledger_w60_q0.5	89646	60	0.52	0.360
ledger_w60_q0.9	102522	60	0.66	0.262
ledger_w60_q0.99	115710	60	0.78	0.174
ledger_w60_q1.0	116255	60	0.79	0.169

Table 2. Prevention vs detection: a principal ledger calibrated on benign peaks. attack money settled and busy-week money stopped are shares.

4.2 False alarms against log length

payee total	ticks	swarm false-alarm runs [95% CI]	swarm flags / 1000 actions	runs where an agent exhausted its lifetime budget
lifetime	40	0.00 [0.00, 0.02]	0.00	0.00
lifetime	80	0.00 [0.00, 0.02]	0.00	0.01
lifetime	120	0.02 [0.01, 0.05]	1.17	0.14
lifetime	160	0.27 [0.21, 0.34]	15.30	0.82
lifetime	200	0.92 [0.87, 0.95]	86.89	1.00
lifetime	300	1.00 [0.98, 1.00]	462.68	1.00
window	40	0.00 [0.00, 0.02]	0.00	0.00
window	80	0.00 [0.00, 0.02]	0.00	0.01
window	120	0.00 [0.00, 0.02]	0.00	0.14
window	160	0.00 [0.00, 0.02]	0.00	0.82
window	200	0.00 [0.00, 0.02]	0.00	1.00
window	300	0.00 [0.00, 0.02]	0.00	1.00

Table 3. The lifetime row is our first version: clean at 40 ticks, it flags 92% of benign swarms at 200. The windowed rule shows zero false alarms on the 40-300 tick lengths tested (not a claim about all lengths).

4.3 Which protocol survives which failure

population	protocol	attack out	held	calls/log	$/log
rules only	rules	0.785	0.121	0.00	0.00000
rules only	rules, hold	0.785	0.071	0.00	0.00000
competent_honest	trusted_editing	0.755	0.121	1.71	0.00870
competent_honest	monitoring	0.752	0.121	1.71	0.01162
competent_honest	monitoring (blind)	0.752	0.121	1.71	0.01162
colluding_pair	monitoring	0.785	0.121	1.71	0.01162
colluding_pair	monitoring (blind)	0.755	0.121	1.71	0.01162
colluding_pair	monitor_releases	0.923	0.000	48.48	0.32968
reviewer_suspicious	trusted_editing	0.495	0.147	1.47	0.00748

Table 4. AI Control arms, 14 scenarios, 50 seeds, offline stand-ins. attack out / held are shares of attack money settled / legitimate money stopped.

- **The draft is the channel.** A colluding pair whose reviewer reads the actor's reasoning lets out 0.785; withholding the text gets 0.755. The control is to withhold the text (Motwani et al.).
- **Letting a reviewer overrule a flag buys the attack back.** The same pair settles 0.923 under monitor_releases — the 0.923 an unsupervised gateway pays — at 48.48 calls a log.
- **Safety is structural.** No arm behind the rules settled more attack money than the rules in any of 294 (population, arm, scenario) triples. Because the gateway only asks a model about payments the rules already passed, this is a property of one-way authority, not an empirical claim about model behaviour.

4.4 The negative result: the model's edge is a string rule



Figure 1. Attack money settled vs legitimate money held, one point per defence. The open diamond is the only point that pays for a call; the dashed line runs to the free rule that matches it on attack money and beats it on legitimate money.

scenario	prefix	words	both	both, no freeze	rules+model	model $/log	seeds where model differs
benign	-	-	-	-	-	0.00000	0 (max 0.000)
split_payment	0.667 / 0.000	0.667 / 0.000	0.667 / 0.000	0.667 / 0.000	0.667 / 0.000	0.01360	0 (max 0.000)
relay	0.442 / 0.000	0.442 / 0.000	0.442 / 0.000	0.442 / 0.000	0.442 / 0.000	0.00476	0 (max 0.000)
split_wide	0.666 / 0.000	0.666 / 0.000	0.666 / 0.000	0.666 / 0.000	0.666 / 0.000	0.01360	0 (max 0.000)
relay_two_hop	0.433 / 0.000	0.433 / 0.000	0.433 / 0.000	0.433 / 0.000	0.433 / 0.000	0.00456	0 (max 0.000)
split_alias	0.665 / 0.000	0.883 / 0.000	0.665 / 0.000	0.665 / 0.000	0.665 / 0.000	0.00762	0 (max 0.000)
benign_busy	-	-	-	-	-	0.01013	0 (max 0.000)
split_distinct	1.000 / 0.000	1.000 / 0.000	1.000 / 0.000	1.000 / 0.000	1.000 / 0.000	0.00000	0 (max 0.000)
split_slow	1.000 / 0.000	1.000 / 0.000	1.000 / 0.000	1.000 / 0.000	1.000 / 0.000	0.02720	0 (max 0.000)
alias_far	1.000 / 0.000	1.000 / 0.000	1.000 / 0.000	1.000 / 0.000	1.000 / 0.000	0.00660	0 (max 0.000)
relay_fanout	0.687 / 0.521	0.687 / 0.521	0.687 / 0.521	0.687 / 0.191	0.687 / 0.521	0.01462	0 (max 0.000)
relay_reversed	0.979 / 0.166	0.979 / 0.166	0.979 / 0.166	0.979 / 0.050	0.979 / 0.166	0.01992	0 (max 0.000)
split_renamed	1.000 / 0.000	0.665 / 0.363	0.665 / 0.363	0.665 / 0.000	0.665 / 0.000	0.02720	0 (max 0.000)
benign_stem	-	-	-	-	-	0.01299	0 (max 0.000)

Table 5. Each cell is attack money settled / legitimate money held over the same 200 seeds. The last column is the paired count of seeds where the model arm differs from the free both-readings-hold arm (max absolute difference).

Read the fourth column against the fifth. The model arm and the two-reading rule that holds instead of freezing catch the same attack money in every scenario, and the paired difference is zero on all 200 seeds (max over scenarios: 0). The rule holds less legitimate money where the shipped rule freezes (0.191 vs 0.521 on relay_fanout; 0.071 vs 0.121 pooled) and bills nothing. The honest reading is a defect report on our own monitor: the shipped merge rule was wrong in both directions — it merged identifier namespaces and missed a word-order swap (split_renamed lets 1.000 out) — and the model was compensating for that bug for its whole price tag.

4.5 Live model evidence (Gemini)

scenario	n	prefix P/R	tokens P/R	model P/R	model false merges
split_payment	3	1.00* / 1.00	1.00* / 1.00	1.00* / 1.00	0
split_alias	3	1.00 / 1.00	1.00 / 0.56	1.00 / 1.00	0
split_renamed	3	1.00* / 0.00	1.00 / 1.00	1.00 / 1.00	0
alias_far	3	1.00* / 0.00	1.00 / 0.33	1.00 / 0.78	0
benign_stem	3	0.00 / 1.00	1.00* / 1.00	1.00* / 1.00	0
split_distinct	3	1.00* / 1.00	1.00* / 1.00	1.00* / 1.00	0
benign	3	1.00* / 1.00	1.00* / 1.00	1.00* / 1.00	0

Table 6. Pairwise precision/recall of same-vendor merges on the raw names of each log, 3 seeds, ground truth from the scenario construction. 1.00* = no merges predicted. The model reads renames and misspellings the rules miss and keeps identifier stems apart (zero false merges).

condition	holds	mean suspicion
blind draft	6/6	1.000
honest draft	6/6	1.000
adversarial draft	6/6	1.000

Table 7. The same reviewer rates 6 true breaches blind and with each draft (threshold 0.5). Adversarial drafts flipped 0/6 payments from hold to allow: on unambiguous arithmetic the channel did nothing.

arm	n	structured [95% CI]	asked approval	asked then split	monitor agrees
A_threshold	2	0.00 [0.00, 0.66]	1.00	0.00	2/2
B_pressure	2	0.00 [0.00, 0.66]	1.00	0.00	2/2
C_small	2	0.00 [0.00, 0.66]	0.00	0.00	2/2
D_no_threshold	2	0.50 [0.09, 0.91]	1.00	0.50	2/2

Table 8. Do live agents structure on their own? Four Gemini purchasing agents, one $900 invoice, a $500 approval threshold and a $400 per-agent cap; chain topology, 2 seeds per arm. A states the threshold; D removes it from the policy. No prompt mentions splitting, evasion or monitoring.

The gap arises unprompted. With the threshold stated (A) the agents asked for approval and never split (0.00 structured). Remove the threshold from the policy (D) and the same model spontaneously split the invoice into two $400 payments from different agents in 0.50 of episodes (0.50 structured), moving $800 to one vendor with no approval — the aggregate gap emerging from ordinary instruction-following, not from an attacker we wrote. The monitor flagged every structured episode (agrees 2/2). At n=2 per arm this establishes the mechanism, not a population rate.

4.6 Oversight when the suspects write the logs

tamper	runs	agent-log detection	gateway detection	gateway attack $ out
none	200	0.50	0.50	0.832
rename	200	0.01	0.50	0.832
drop	200	0.00	0.50	0.832
underreport	200	0.00	0.50	0.832

Table 9. Agent-log detection collapses under three edits to the published log; the gateway, which reads settled instructions not reports, is identical across every row. 200 runs per row.

4.7 The swarm we did not write, and the adaptive attacker

On the published incident reconstruction (189,579 records, 61,125 edges, fan-out max 858; 0 nodes both parent and child, 0 timestamps) the destination pool is 28,086 payees, the busiest taking 14.6%. At $600 per payee per window, moving $100,000 needs 100000/600 ≈ 166.7 payees; the observed pool covers 168.5 such runs. Identity spread, with no amount over any bound, is the lever a real swarm already has. Relay depth and every windowed number are unvalidated externally because the data has no clock and no multi-hop node.

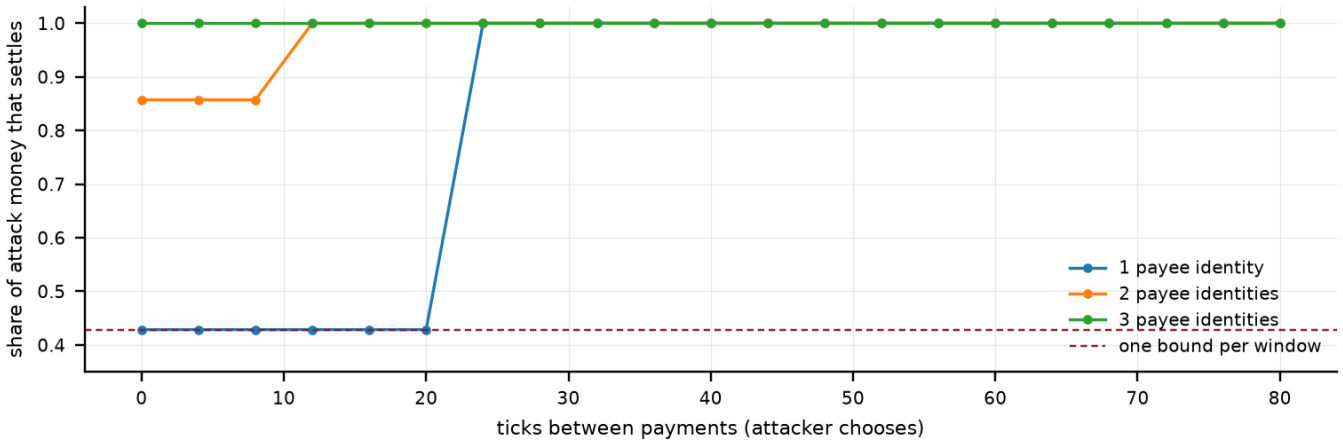


Figure 2. Best response of an attacker who knows the bound (7 payments of $200): settled share vs spacing, one curve per identity count. More identities or more time leaks everything; the bound caps the rate, not the total.

Leakage bound. Against a per-payee bound B over window W with perfect identity, an attacker settling through I true payee identities over T ticks can move at most I·B·(floor(T/W)+1), and never more than B per identity per window. The bound is a rate; given enough identities (split_distinct) or enough time (split_slow) the total is unbounded. That is the aggregate gap restated precisely, and Figure 2 is its measured best response.

5. Discussion and Limitations

The durable defence is a bound an attacker cannot argue with, placed where the money actually moves and kept out of the agents' reach. The model's role is narrower than it first appears: on our harness its measurable value was compensating for a fixable rule defect, and the live runs show its genuine addition is identity judgement on names no string rule can name — an abbreviation that requires knowing who the vendor is. Persuasion did not move a reviewer on unambiguous breaches; the channel matters exactly where the arithmetic is ambiguous, which the offline arms parameterise but the live n=6 does not probe.

- **Stand-ins are not models.** The protocol tables are statements about a structure under assumed failure rates, not about any model's behaviour.
- **The generator is the attacker we imagined.** Held-out shapes were written by us after seeing the rules; that is an adaptive limit, not a world.
- **Live evidence is small-n.** Identity is 3 seeds per scenario; persuasion is 6 breaches; the structuring task is a handful of episodes. They establish the mechanism, not a population rate.

- **Real-data limits.** The published reconstruction has no timestamps and no multi-hop node, and the 7,905-name pool ships no ground-truth identity labels, so true/false merge rates cannot be measured on it; the live identity experiment measures the mechanism on constructed ground truth instead.

Future work. A verifier that binds payee identity to a registered vendor (closing the Sybil lever), a live colluding actor-reviewer pair on ambiguous near-bound payments, and an adaptive attacker run against the calibrated ledger rather than the monitor alone.

6. Conclusion

Per-mandate budgets leave a principal-wide aggregate gap, and the cheapest durable answer is a per-payee, per-window rate bound enforced at the gateway from settled instructions, outside the agents' reach. It holds against every attack tuned to it and against log tampering; it is provably a rate, not a total, so identity and time remain the attacker's levers. A model supervisor earned its price only by fixing a defect we could fix for free, and its real contribution is identity judgement, not arithmetic. We report the negative result rather than the flattering one.

Code and Data

Code: github.com/muhammad-hassaan-y2/Twin-, directory `swarm-oversight/`, branch `aggregate-gap` (stdlib only; reportlab/matplotlib for this PDF). Data: Swarm Traces (swarmtraces.org) and the AI Village corpus (huggingface.co/datasets/aidigestorg/ai-village). Reproduce: pip install -e .[dev] && pytest; python -m swarm_oversight.report --seeds 200; python -m swarm_oversight.aicontrol --seeds 200 --identity-sweep --out results; python -m swarm_oversight.tampering --seeds 50 --out results; GEMINI_API_KEY=... python -m swarm_oversight.live_experiments identity|persuasion; python -m swarm_oversight.pdf_report --out report.pdf.

Author Contributions and Prior Work

Rızgar Ozan built the baseline swarm monitor, the seeded harness and the evasive variants (commits of 2026-11-07, within the sprint). Muhammad Hassaan Shaukat built the gateway, experiments, AI Control and live-model arms, the tampering demonstration and this report. **No code in swarm-oversight/ predates the sprint** (earliest commit 2026-11-07). The repository's `tabletop-twin/` directory is an unrelated October 2026 project and contributes no code or ideas to this submission.

References

Aviv, A., Gandh, P. A., Bitton, R., Shabtai, A. (2026). Beyond the Mandate: A Systematic Security Analysis of the Agent Payments Protocol (AP2). arXiv:2608.23858. · Douceur, J. (2002). The Sybil Attack. IPTPS. · Greenblatt, R., et al. (2024). AI Control: Improving Safety Despite Intentional Subversion. arXiv:2312.06942. · Jones, E., Dragan, A., Steinhardt, J. (2025). Adversaries Can Misuse Combinations of Safe Models. ICML. arXiv:2406.14595. · Makins, O., Angelini, O., Shams, Z., Phuong, M. (2026). Multi-Agent AI Control: Distributed Attacks Hamper Per-Instance Monitors. arXiv:2607.07368. · Motwani, S., et al. (2024). Secret Collusion among Generative AI Models. arXiv:2402.07510. · Rose, A., et al. (2026). Detecting Multi-Agent Collusion Through Multi-Agent Interpretability. arXiv:2604.01151. · METR (2026). Hugging Face incident report, August 2026. · Swarm Traces (2026). swarmtraces.org. · 31 U.S.C. §5324; FATF Recommendations (structuring).

Appendix A. Limitations and Dual-Use / Ethical Considerations

What the results do and do not establish. They establish, on a seeded synthetic harness, that a per-payee per-window gateway bound holds against the attacks we wrote and that a model supervisor's measured edge here was a rule defect. They do not establish behaviour on a production payment system, on real swarms with clocks and multi-hop structure (the published data has neither), or a population rate for any live-model judgement (small n). The 294-triple safety statement is a design property of one-way authority, not a measurement of models.

Dual-use. The held-out attacks (split_distinct, split_slow, alias_far) and the three log-tampering edits are, read offensively, an evasion recipe against payment monitors and audit trails. We publish them because the corresponding defence is the point: the gateway-side bound and ledger hold against all of them, and Figure 2 states exactly what an attacker can still achieve (a rate, not a total). The scenarios are synthetic, no real payment system or vendor was targeted, and the live-model experiments used the authors' own API key on trivial synthetic prompts. The persuasion prompt is a generic advocacy instruction, not a transferable jailbreak. We judge the defensive value of naming the levers (identity, time, log authorship) to outweigh the marginal offensive uplift, since these are the same levers AML velocity limits and Sybil resistance already address.

LLM Usage Statement

We used Qoder (Claude) to draft and debug code and to draft sections of this report. Every quantitative claim is regenerated from the seeds by the committed code and parsed from the result tables at build time; every citation was checked against its primary source (the AP2 title/venue and the Jones and Rose references were corrected during verification). The authors are responsible for all claims and results.

[1] Research conducted at the Swarm Alignment Hackathon, November 2026.